

Network Security

Chapter 3

本章內容繁多，必須抓住大綱才不致迷失在名詞之海中。

中央大學 資管系

陳奕明

The Target Breach

- Attacks and Attackers
- Protecting Dialogs Cryptographically
- Other Forms of Authentication
- Firewalls
- Antivirus Protection

The Target Breach



- Christmas Season **2013**
- Black**POS** malware “scrapes” transaction data
- **Debit/credit transactions** of **40 million customers**
- In separate attack, information stolen on 70 million Target customers
- Sales losses, stock decline, **technology officer fired, CEO fired**



3.1 The Target Breach (1/5)

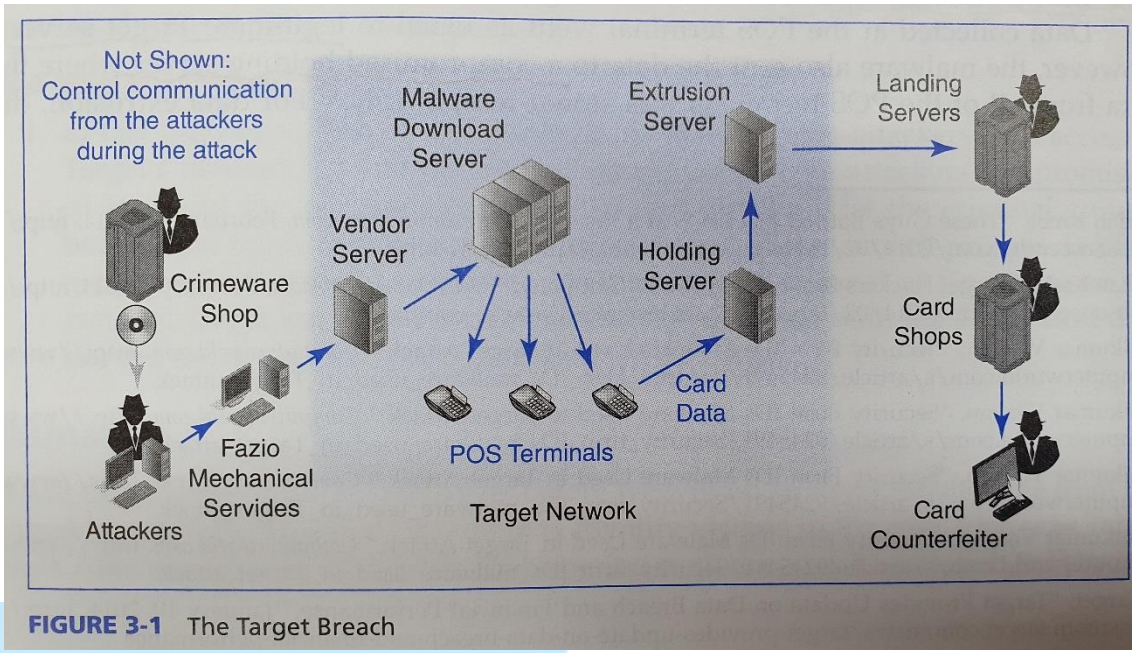
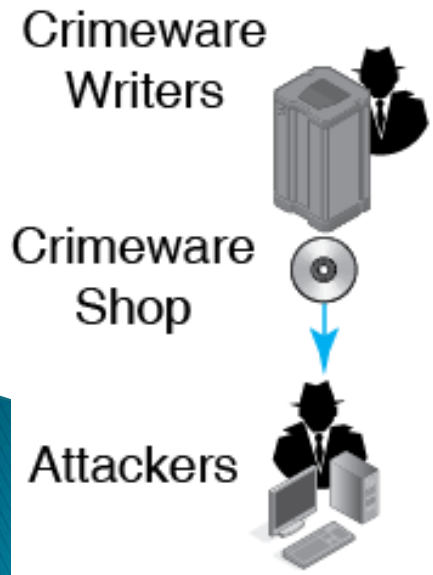


FIGURE 3-1 The Target Breach



Target Network

BlackPOS

3.1 The Target Breach (2/5)

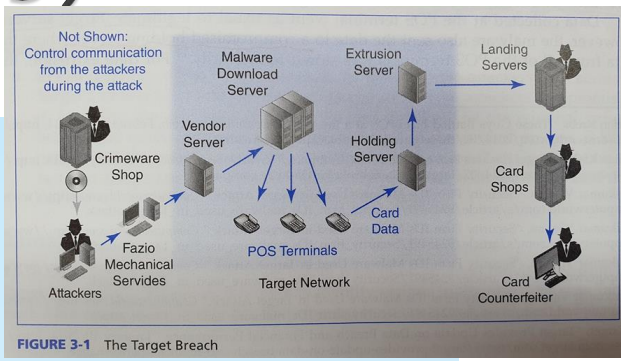


FIGURE 3-1 The Target Breach

Target Network

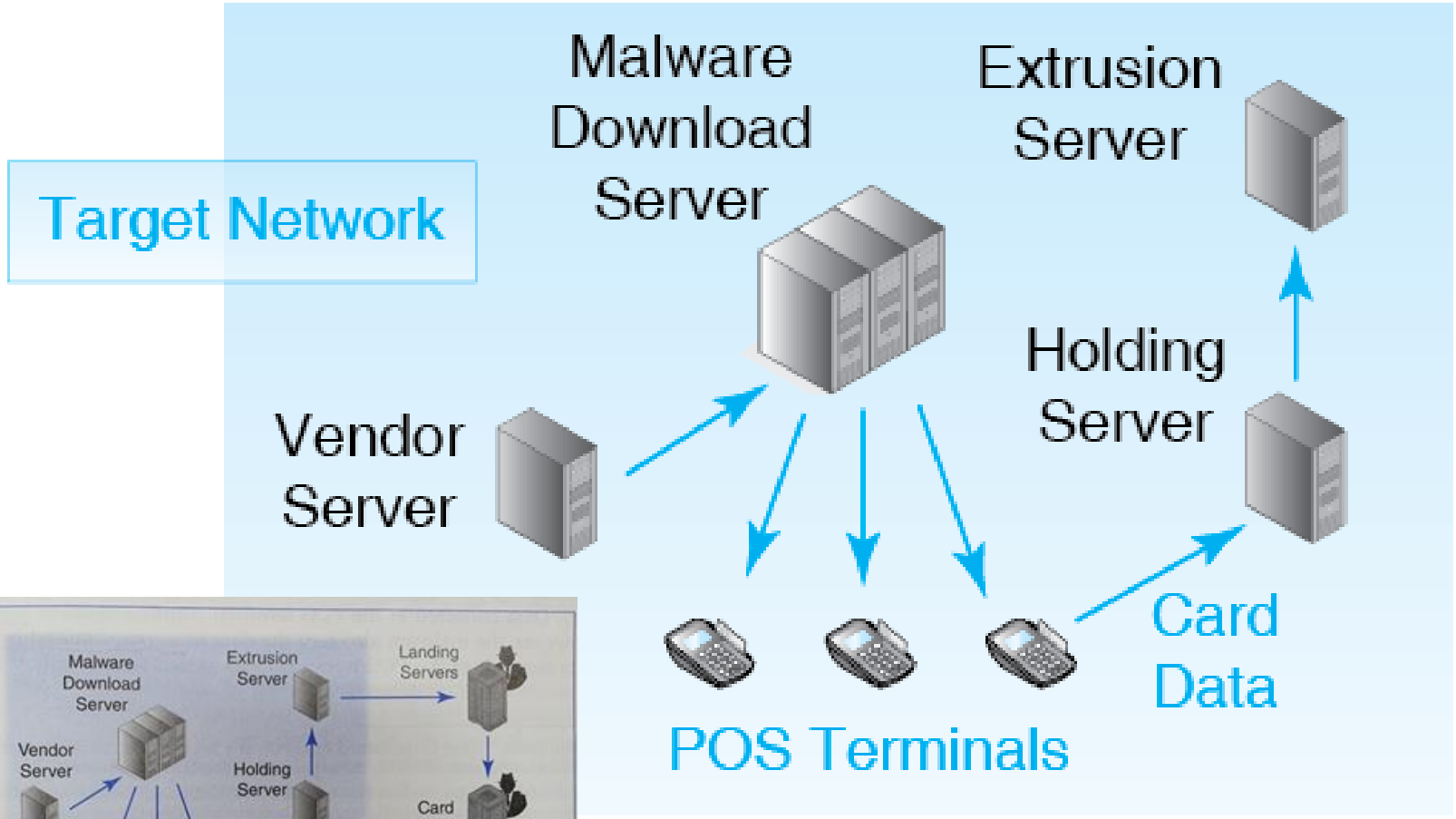
E-Mail Spear Phishing Attack

Vendor Server

Attackers

Fazio Mechanical Services

3.1 The Target Breach (3/5)



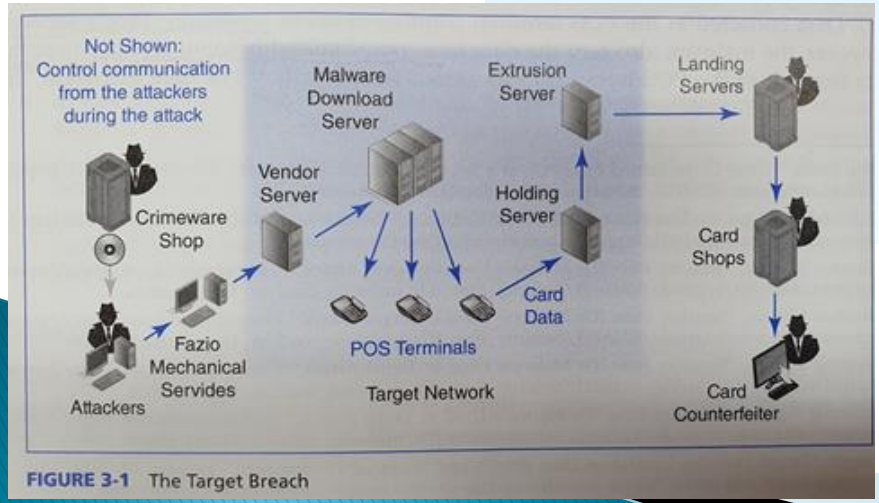
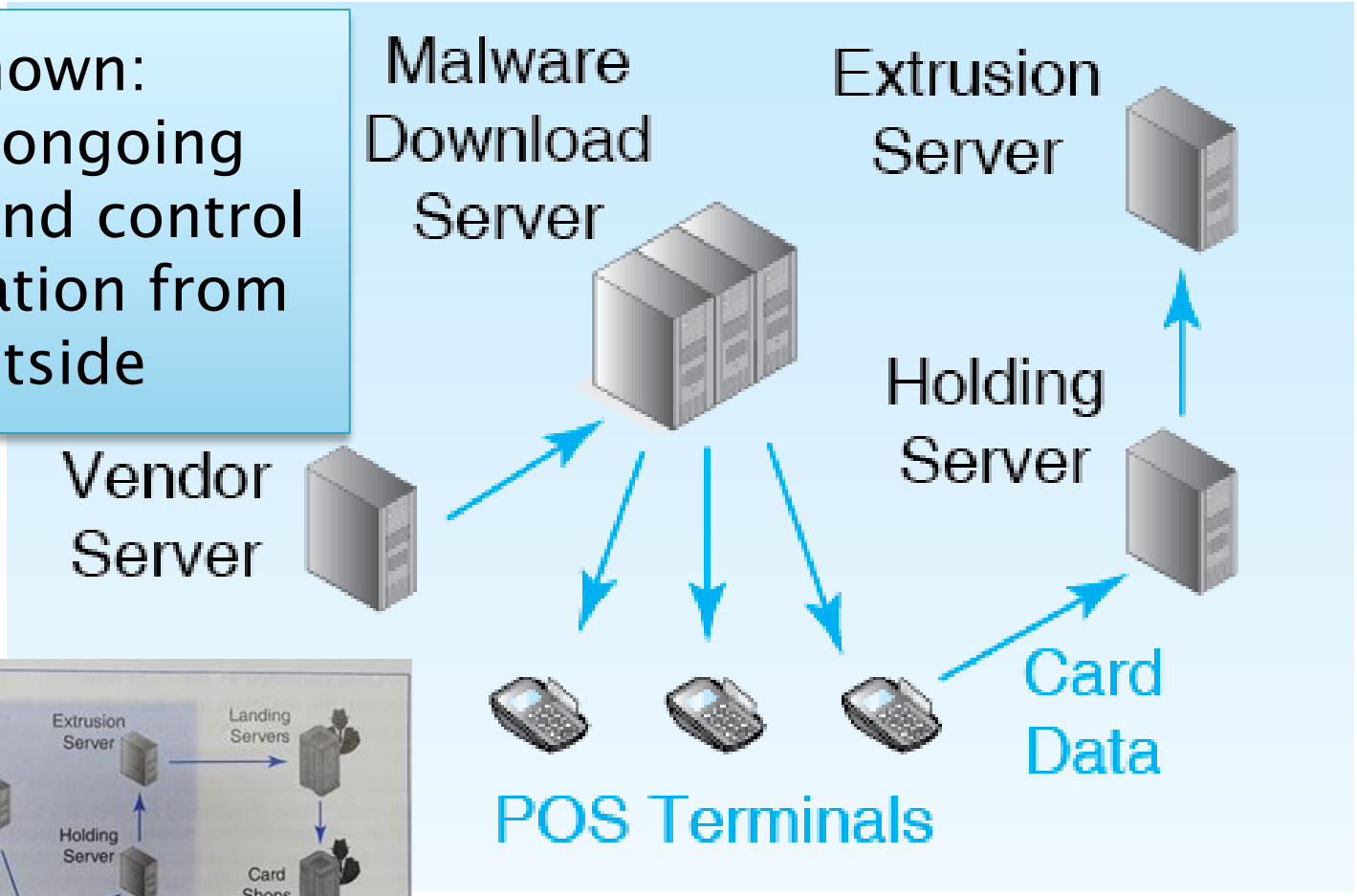


FIGURE 3-1 The Target Breach

3.1 The Target Breach (4/5)

Not shown:
Constant ongoing command and control communication from the outside



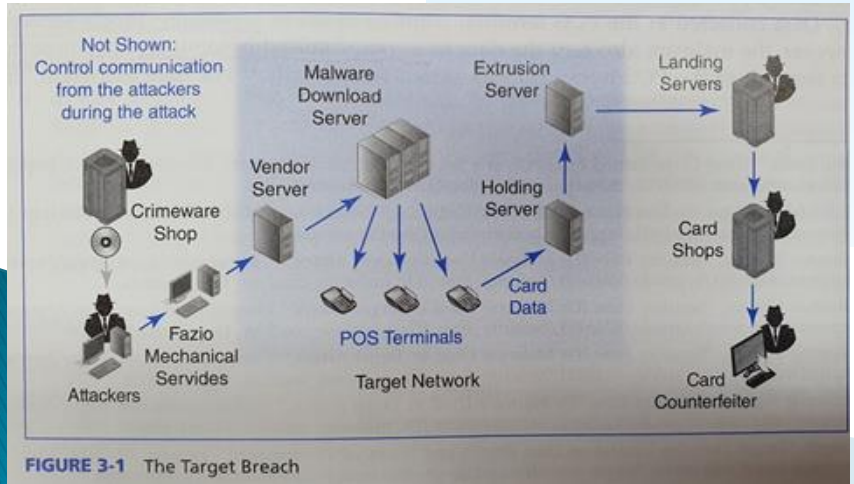
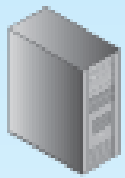


FIGURE 3-1 The Target Breach

3.1 The Target Breach

Extrusion Server





Card Shops

Card Counterfeiter

Target Network

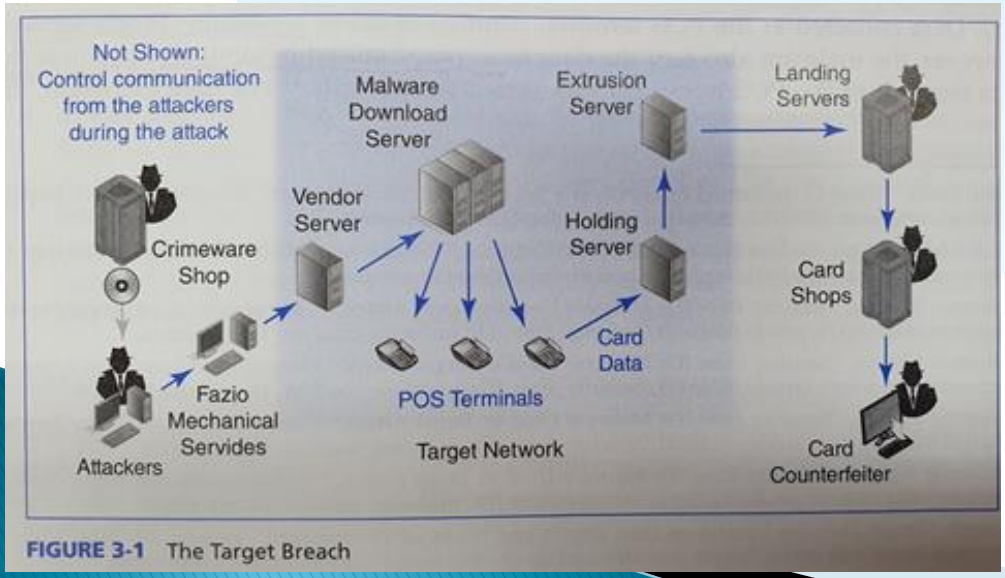


FIGURE 3-1 The Target Breach

Another Case study: STEUBEN ARC

- Nonprofit organization in Bath, New York
- September 2009, stole nearly $200,000
- Fake invoice in e-mail message with an attachment, dhlinvoice.zip, to an accountant
- Keystroke logger to get the accountant's user name and password on the accounting server
- 20 money mules to offshore accounts controlled by the attackers
- A successful attack

延伸閱讀：
Systematically Understanding the Cyber Attack Business- A Survey, *ACM Computing Surveys*, July, 2018

- The Target Breach
- **Attacks and Attackers**
- Protecting Dialogs Cryptographically
- Other Forms of Authentication
- Firewalls
- Antivirus Protection

3.2 Malware

- Malware is a general name for evil software
- Vulnerabilities are security flaws in specific programs.
- Vulnerability-specific malware requires a specific vulnerability to be effective.
- Vendors release patches to close vulnerabilities.
  - However, users do not always install patches promptly or at all and so continue to be vulnerable.
  - Also, zero-day attacks occur before the patch is released for the vulnerability.

Malware – Viruses



- Pieces of code that attach themselves to other programs.
- Virus code executes when an infected programs executes.
- Propagation vectors between hosts
  1. E-mail attachments
  2. Visits to Websites (even legitimate ones)
  3. Social networking sites
  4. Many others (USB RAM sticks, peer-to-peer file sharing, etc.)

Malware –Worms



- stand-alone programs that do not need to attach to other programs.
- Can propagate like viruses through e-mail, etc.
  - This requires human gullibility, which is slow.
- Directly-propagating worms jump to victim hosts directly.
  - Can only do this if target hosts have a specific vulnerability.
  - Directly-propagating worms can spread with amazing speed.
  - No action is necessary on the part of the victim

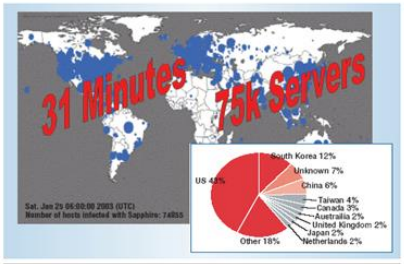


Figure 2. SQL Slammer worm attack. On 25 January 2003, the worm infected more than 75,000 servers around the world in a mere 31 minutes.

Slammer worm,Jan.25, 2003

3.4 Other Types of Malware –Mobile Code on Webpages

- HTML Web pages can contain scripts(Mobile code).
  - Scripts are **snippets of code** executed **when the Webpage is displayed in a browser**.
  - A common scripting language is JavaScript.
  - Scripts are normally benign but may be damaging if the browser has a vulnerability.
    - The script may do damage by itself or download a program to do damage.

Q1:你知道為什麼叫『Mobile』嗎？

3.4 Other Types of Malware

- **Trojan Horses**
  - Trojan horses are programs that disguise themselves as system files
  - Spyware Trojans collect sensitive data and send the data to an attacker
- **Downloaders**
  - Malware that downloads a larger malware program onto the infected computer
- **Spam**
  - Unsolicited Commercial E-Mail

3.5 Payloads



- Examples:
  - erase hard disks or downloads another program (the latter payload named as downloader) .
- Many downloaded programs are Trojan horses.
  - Trojan horses are programs that disguise themselves as system files.
  - Spyware Trojans collect sensitive data and send the data they collect to an attacker.
    - Website activity trackers
    - Keystroke loggers, Data mining software, etc.

Attacks on Individuals (1/3)

- Social Engineering
  - Tricking the victim into doing something against his or her interests
- Fraud
  - Lying to the user to get the user to do something against his or her *financial* self-interest

2013-03-11 工作狂老闆搥心肝 駭客空中劫財 600萬貨款沒了

- Spam
  - Unsolicited commercial e-mail
  - Often used for fraud

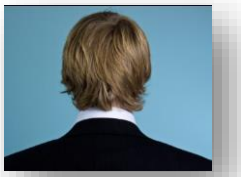
3.4 Attacks on Individuals (2/3)

- Spam (Cont.)
  - E-Mail Attachments
  - Including a Link to a Website that Has Malware
- Phishing Attacks
  - Sophisticated social engineering attacks in which an authentic-looking e-mail or Website entices the user to enter his or her username, password, or other sensitive information.

Attacks on Individuals (3/3)



- Credit Card Number Theft
  - Performed by “carders” and Make purchases with stolen credit card numbers



- Identity Theft
  - Collecting enough data to impersonate the victim in large financial transactions
  - Can result in much greater financial harm to the victim than carding
  - In corporate identity theft, the attacker impersonates an entire corporation.

Human Break-Ins and Hacking



- Human Break-Ins
  - Viruses and worms only have a single attack method.
  - Humans can keep trying different approaches until they succeed.
- Hacking
  - Informally, hacking is breaking into a computer.
  - Formally, hacking is *intentionally* using a computer resource *without authorization* or in *excess of authorization*.

3.7 Human Break-Ins (Hacking) (1/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *Is it hacking if you find a username and password on the street and log in to the account? Explain.*

3.7 Human Break-Ins (Hacking) (2/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *Is it hacking if you log in to your legitimate e-mail account and find that you can see the e-mail of other users. You spend about five minutes looking around. Is this hacking? Justify your answer.*

3.7 Human Break-Ins (Hacking) (3/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *You click on an e-mail link and find yourself inside an Internal Revenue Service server. Is this hacking? Justify your answer.*

3.7 Human Break-Ins (Hacking) (4/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *Is it hacking if you log into an account that the user gave poor protection to by giving it the password 123456?*

3.7 Human Break-Ins (Hacking) (5/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *Is it hacking if you just want to test the security of your bank and discover that it has a poor firewall?*

3.7 Human Break-Ins (Hacking) (6/6)

- **Hacking**
  - *Intentionally* using a computer resource
  - without authorization or
  - in excess of authorization
- *Is it illegal to test a company's firewall on your own initiative, find a vulnerability, and tell the company that you will tell them about it if they give you $1,000?*

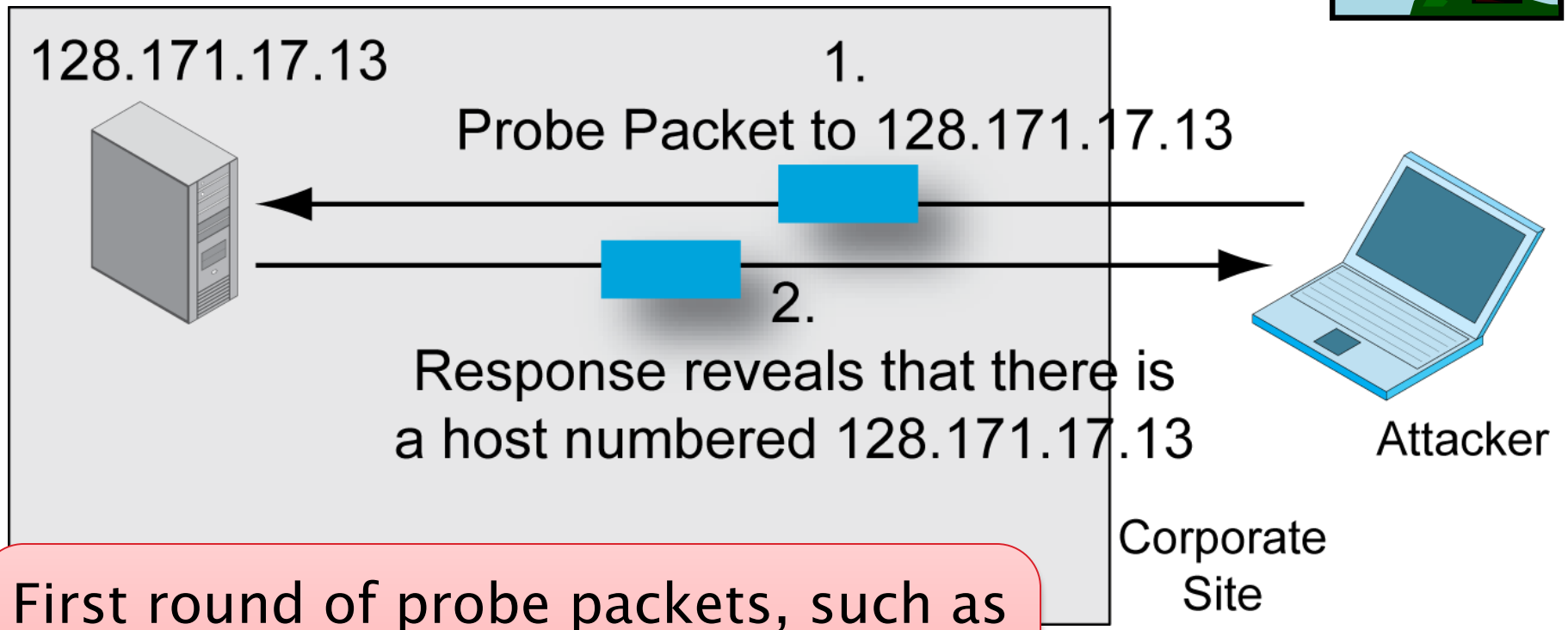
3.8 Typical Stages in a Human Break-In

- Scanning Phase (Figure 3-6)
  - Port scanning by probing
- The Break-In
  - exploit
- After the Break-In
  - Download hacker tool kit (Backdoor, Trojan horse, keystroke logger, etc).

NEXT

Probes and Exploits





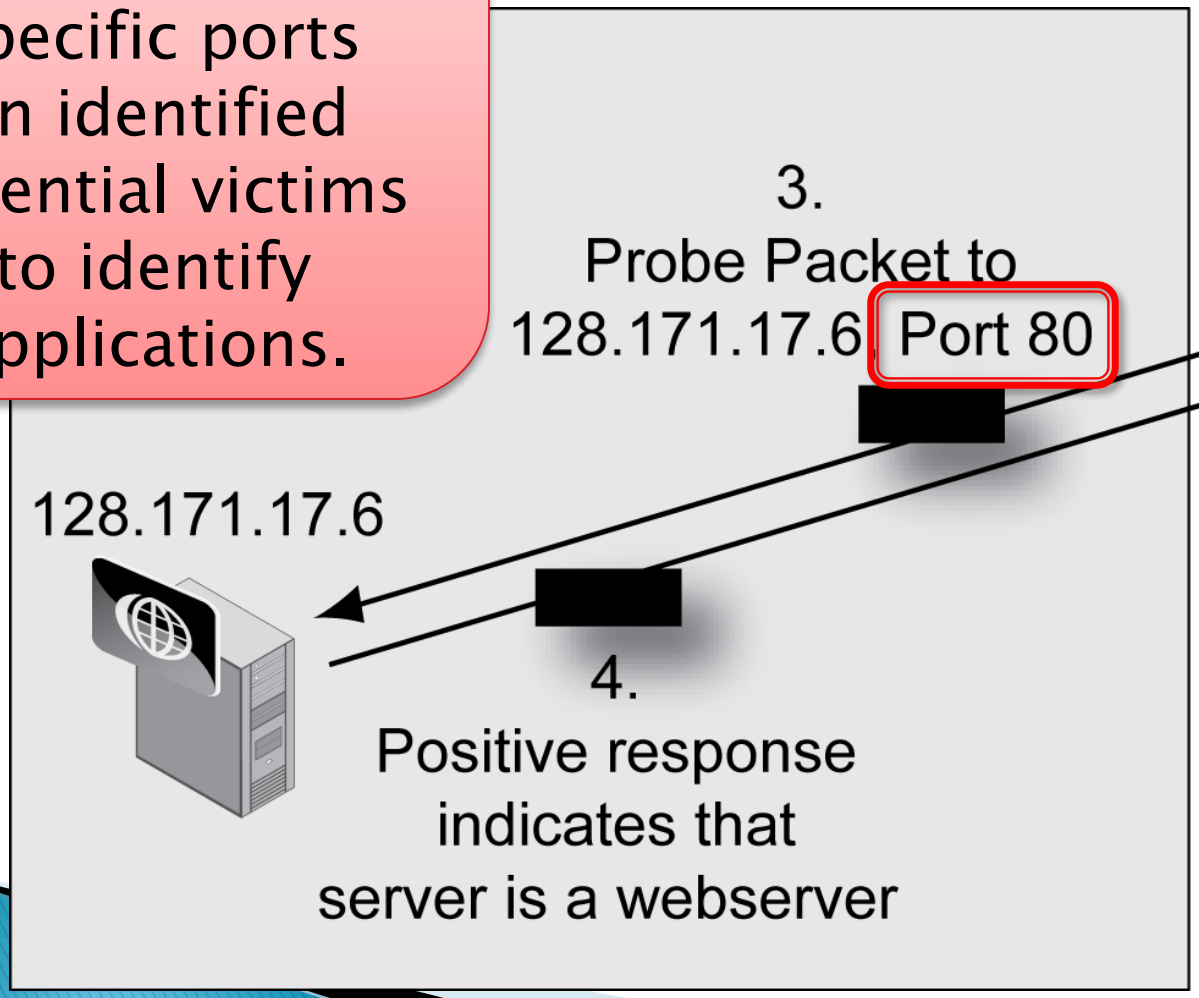
First round of probe packets, such as pings, identify active IP addresses and therefore potential victims.

Continue

Probes and Exploits

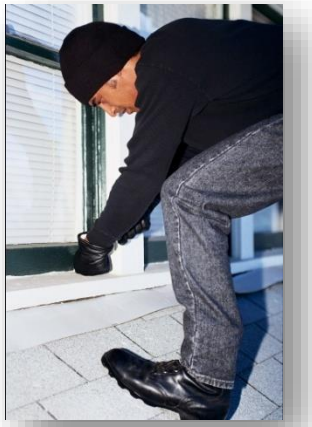


Second round sends packets to specific ports on identified potential victims to identify applications.



BACK

Human Break-Ins

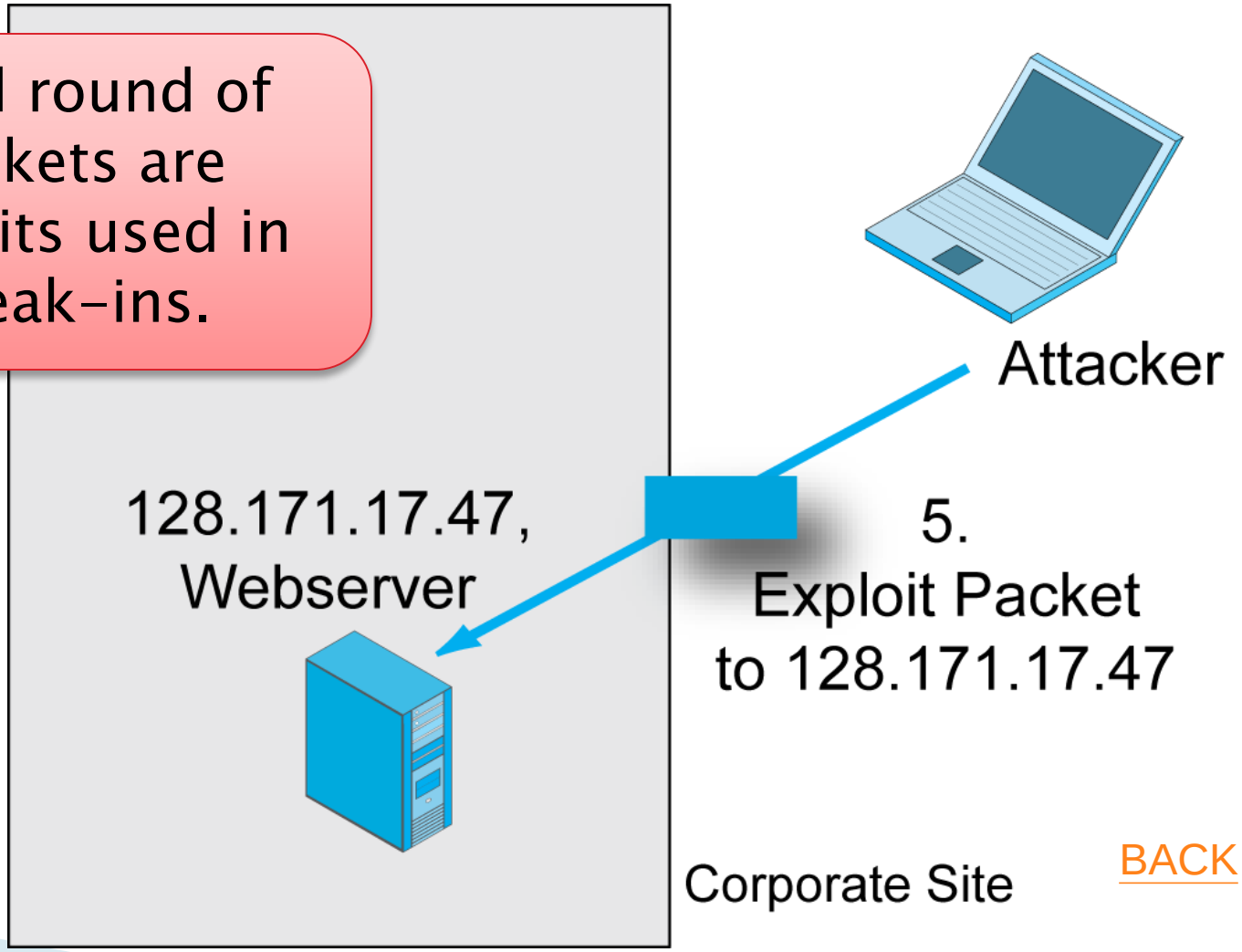


- Stage 2: The Break-In
  - Uses an exploit—a tailored attack method that is often a program (Example).
  - Normally exploits a vulnerability on the victim computer.
  - The act of breaking in is called an exploit.
  - The hacker tool is also called an exploit.

Back

Probes and Exploits

Third round of packets are exploits used in break-ins.



BACK

Human Break-Ins

- Stage 3: After the Break-In (1/2)

  1. The hacker downloads a hacker tool kit to automate hacking work.

  2. The hacker becomes invisible by deleting log files.

  3. The hacker creates a backdoor (way to get back into the computer).

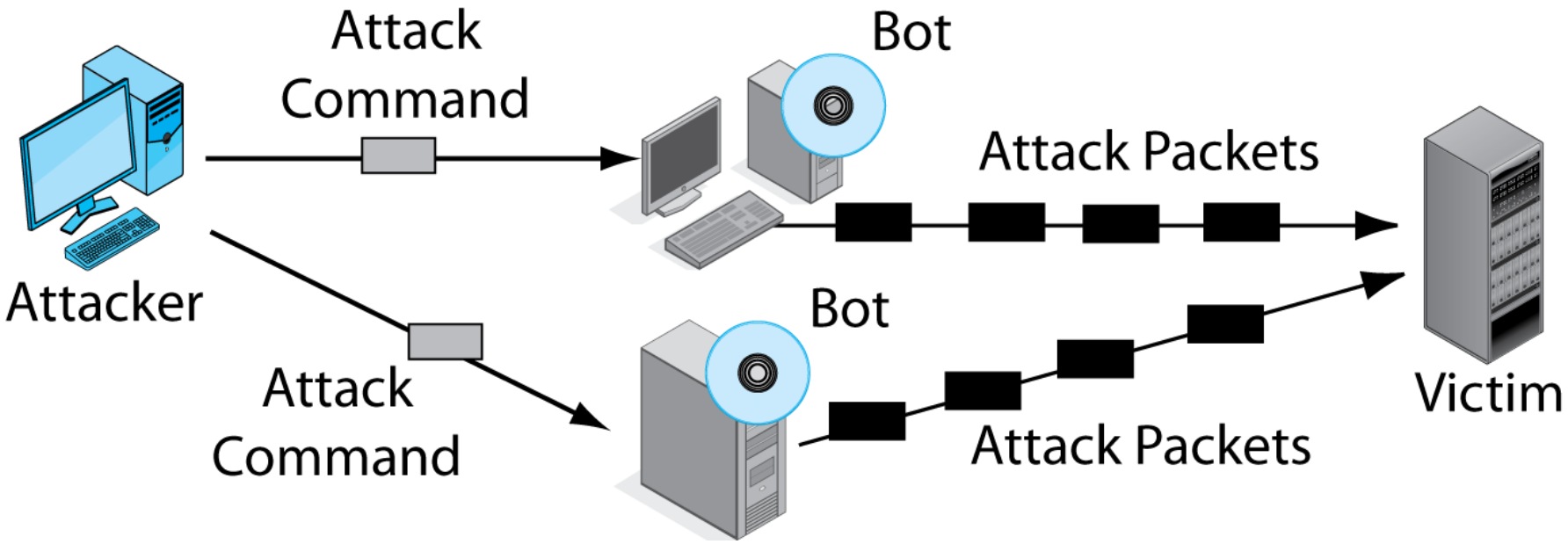
     - Backdoor account—account with a known password and full privileges.
     - Backdoor program—program to allow reentry; usually Trojanized.

Human Break-Ins



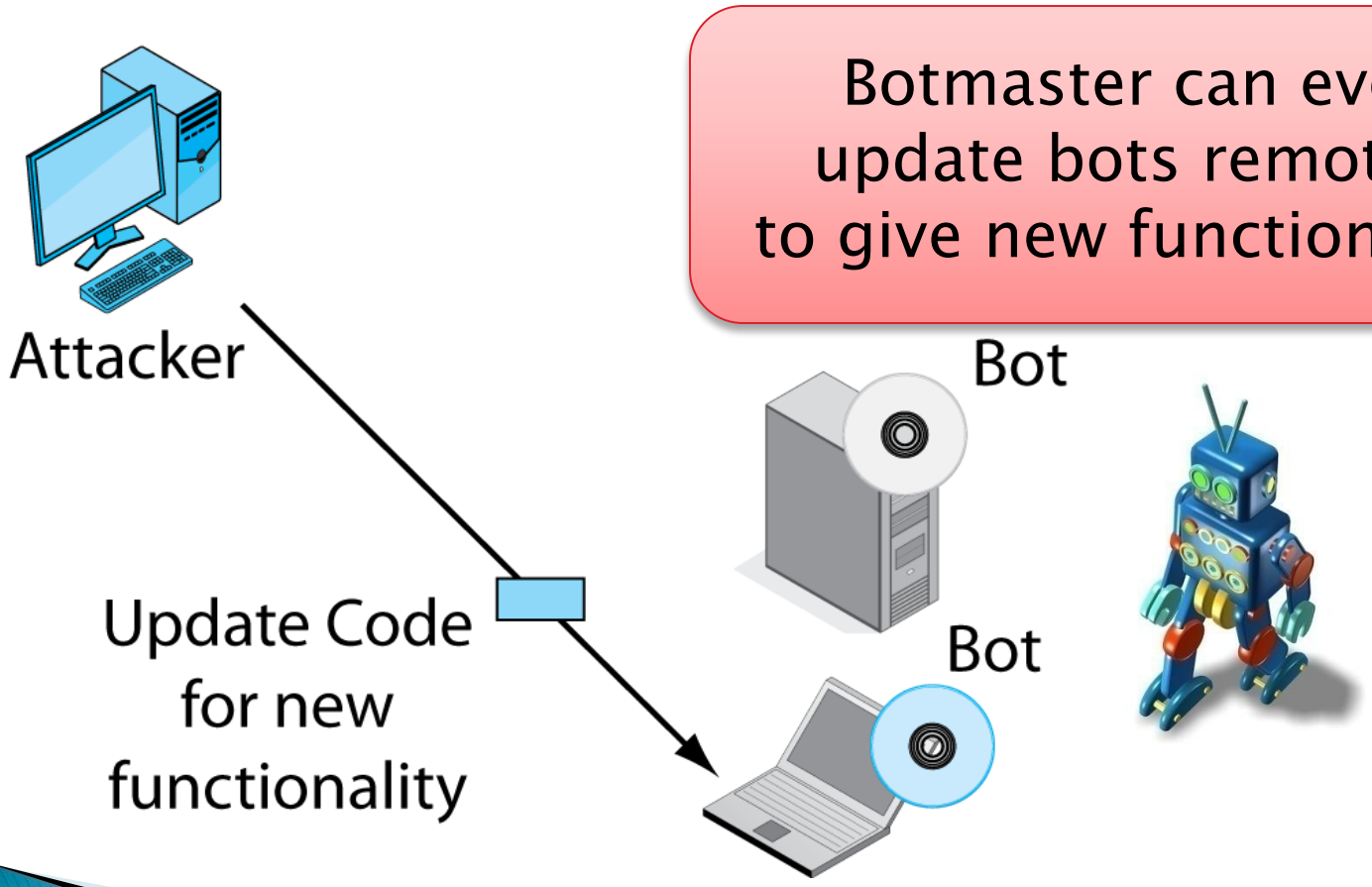
- Stage 3: After the Break-In (2/2)
  - The hacker can then do damage at his or her leisure.
    - Download a Trojan horse to continue exploiting the computer after the attacker leaves.
  - Manually give operating system commands to do damage.

3.7 Distributed Denial-of-Service (DDoS) Attack Using Bots

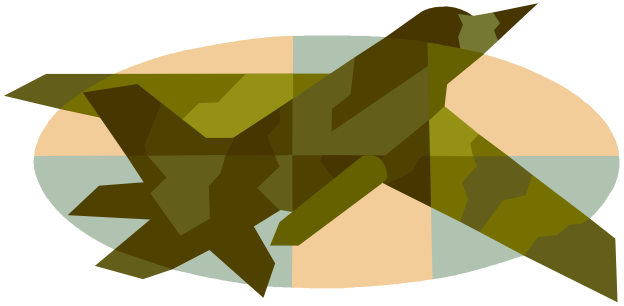


Attacker (botmaster) sends attack commands to Bots. Bots then attack victims.

Distributed Denial-of-Service (DDoS) Attack Using Bots



Types of Attackers



◆APT （Advanced Persistent Threats)

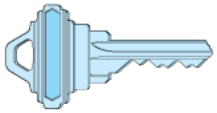
- On the Horizon
  - Cyberattacks by cyberterrorists
    - Cyberattacks on utilities grids
    - Financial disruption
  - Cyberwar by nations
    - Espionage and attacks on utilities and financial infrastructures

- The Target Breach
- Attacks and Attackers
- **Protecting Dialogs Cryptographically**
- Other Forms of Authentication
- Firewalls
- Antivirus Protection

3.12 Symmetric Key Encryption for Confidentiality (1/3)



Symmetric Key



Message "Hello"

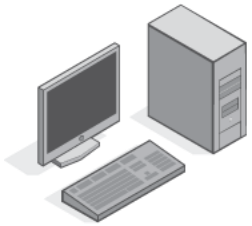
Cipher & Key

Encrypted Message

Eavesdropper



Network



Party A

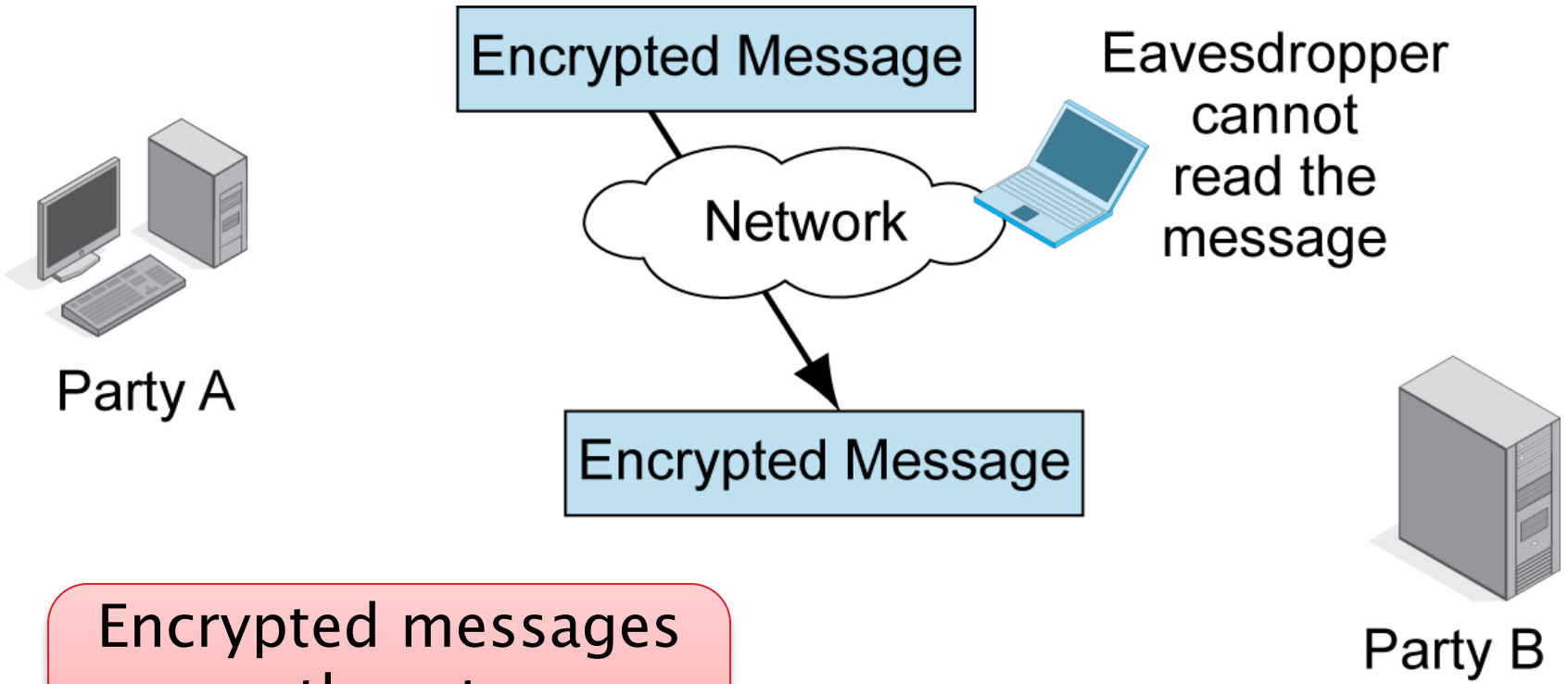
Encryption methods are called ciphers, not codes.

Party B



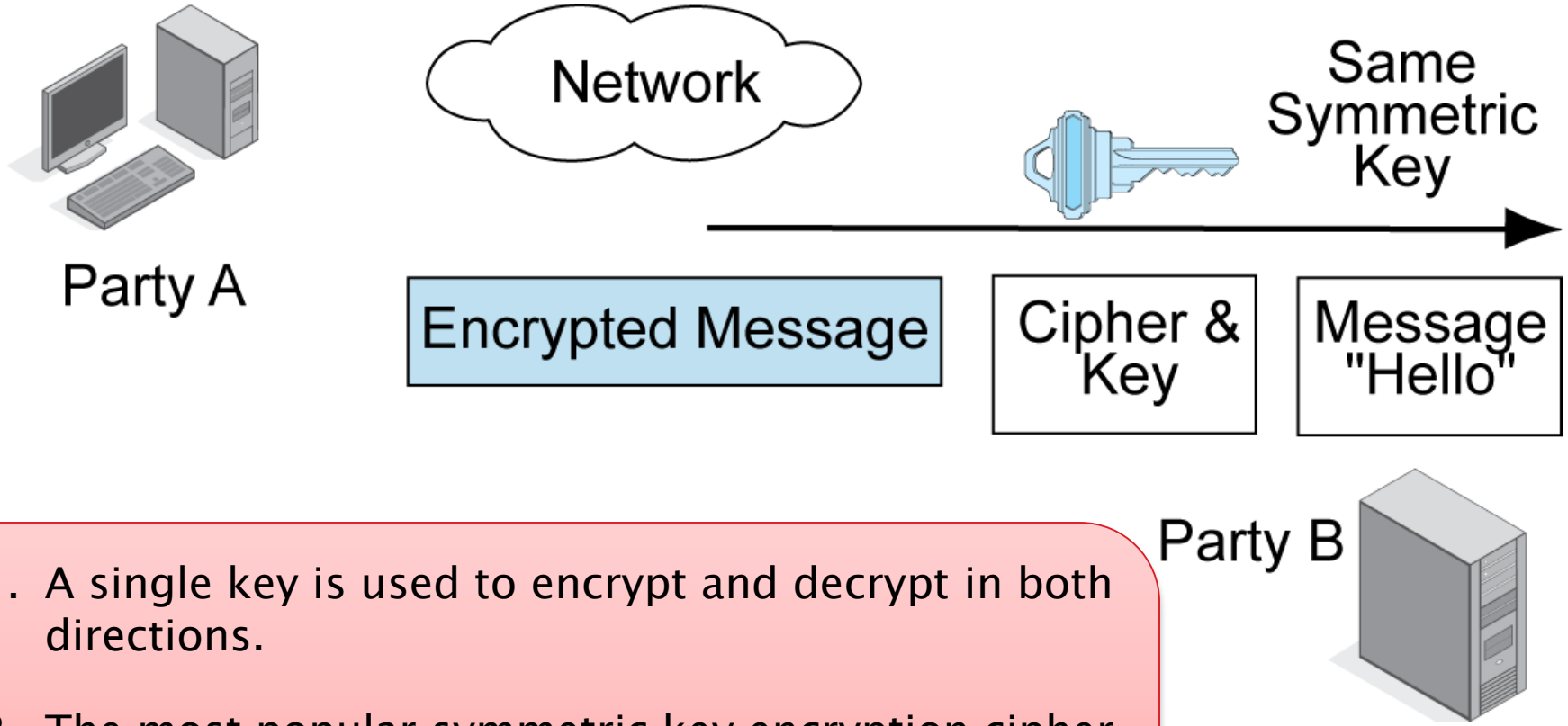
3.12 Symmetric Key Encryption for Confidentiality (2/3)





Encrypted messages thwart eavesdroppers.

3.12 Symmetric Key Encryption for Confidentiality (3/3)



1. A single key is used to encrypt and decrypt in both directions.
2. The most popular symmetric key encryption cipher today is the Advanced Encryption System (AES).
3. Key lengths have to be at least 100 bits long to be considered strong.

3.13 Electronic Signature



Encryption for Confidentiality

Electronic Signature gives Authentication & Message Integrity



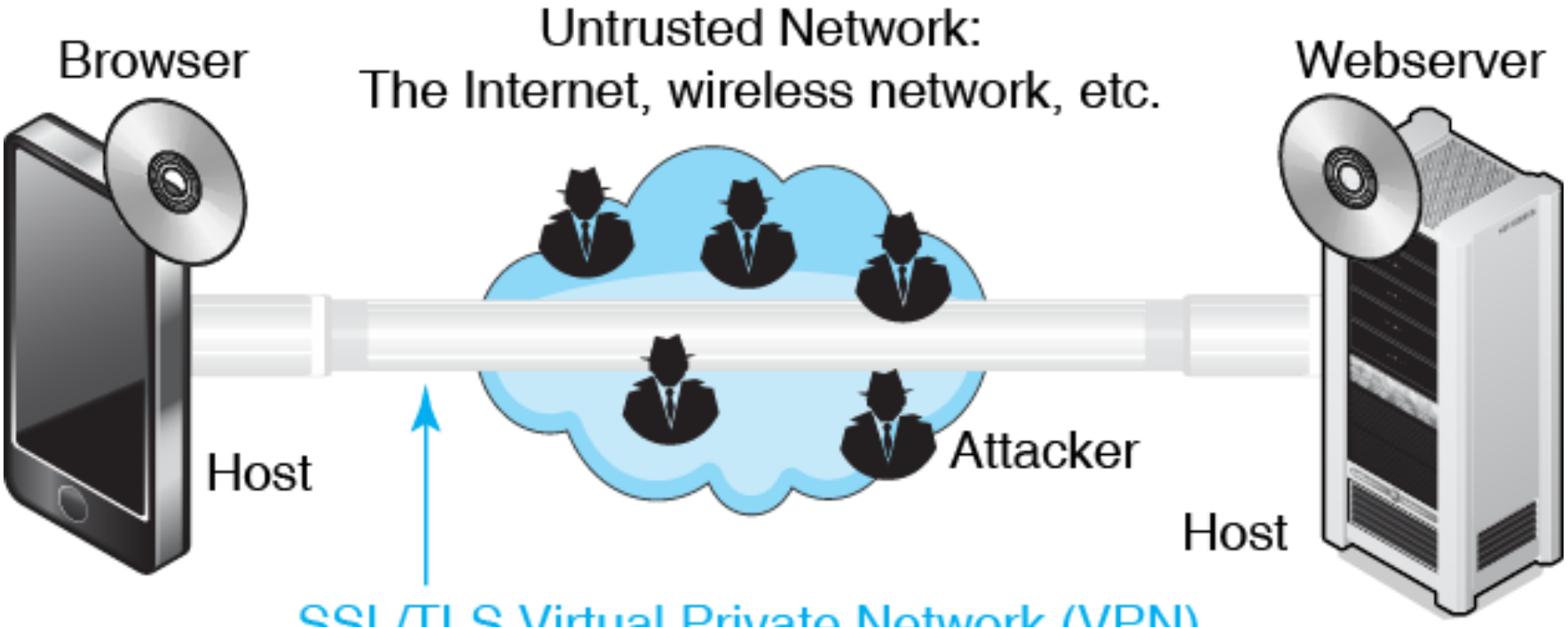






Electronic signatures give message authentication and message integrity.

3.14 SSL/TLS Host-to-Host VPN

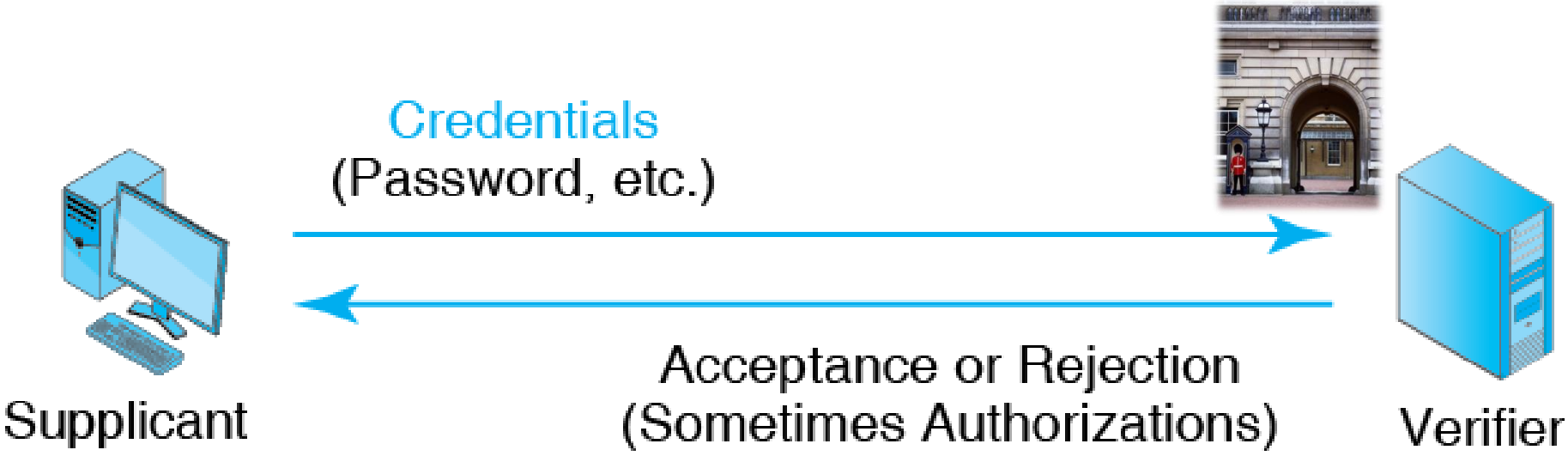


Summary of SSL/TLS

- Cryptographic system standard widely used in sensitive browser-Webserver communication
- Used almost every time you buy online
  - URL has https:// instead of http://
- Pros:
  - Easy to implement because built into every browser and Webserver already
- Cons:
  - Only medium-strength security
  - Cannot protect all applications—used mostly for the World Wide Web and e-mail

- The Target Breach
- Attacks and Attackers
- Protecting Dialogs Cryptographically
- **Other Forms of Authentication**
- Firewalls
- Antivirus Protection

3.15 General Authentication Concepts



- **Controlling Access to Resources**
  - If criminals cannot get access, they cannot do harm.
- **Authentication**
  - The supplicant proves its identity to the verifier by sending its credentials (proofs of identity).

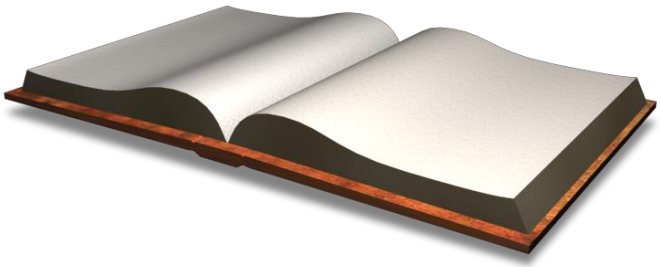
Password Authentication (1 /5)



- Reusable Passwords
  - Strings of characters typed to authenticate the use of a username (account) on a computer.
  - They are used repeatedly and so are called reusable passwords.
- Benefits
  - Ease of use for users (familiar)
  - Inexpensive because built into operating systems

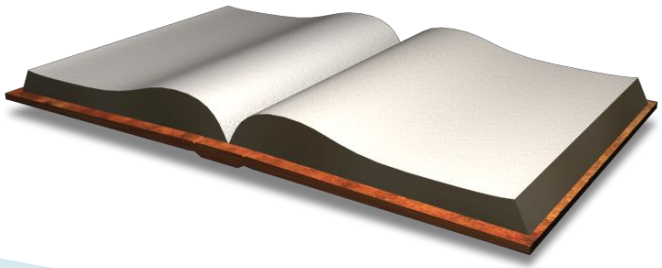
Password Authentication (2/5)

- Often Weak (Easy to Crack)
  - Word and name passwords are common.
    - spot, mud, helicopter, veterinarian
  - They can be cracked quickly with dictionary attacks.
  - Word and name passwords are never adequately strong, regardless of how long they are.



Password Authentication (3/5)

- Hybrid Dictionary Attacks
  - Look for common variations of names and words.
    - Capitalizing only the first letter
    - Ending with a single digit
    - And so on
  - Passwords that can be cracked with hybrid dictionary attacks are never adequately strong, regardless of how long they are.



Password Authentication (4/5)

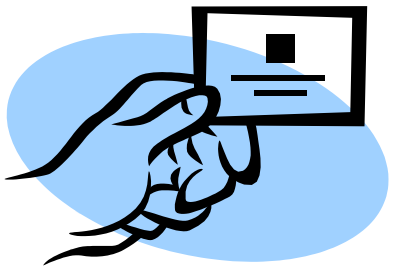
- Passwords Should Be Complex
  - Should mix case, digits, and other keyboard characters ($, #, etc.). *P@ssw0rd 夠複雜嗎？*
  - Complex passwords can be cracked only with brute force attacks (trying all possibilities).
- Passwords Also Should Be Long
  - Should have a minimum of eight characters.
  - Each added character increases the brute force search time by a factor of about 70.
  - *Mississippi, 4$5aB, 34d8%^tdy*

Password Authentication (5/5)

- **Other Concerns**
  - If people are forced to use long and complex passwords, they tend to write them down.
  - People should use different passwords for different sites.
    - Otherwise, a compromised password will give access to multiple sites.
  - Overall, reusable passwords are too vulnerable to be used for high security today.

3.17 Other Forms of Authentication (1/3)

- Perspective
  - Goal is to eliminate reusable passwords.
- Access Cards
  - Permit door access.
  - Proximity access cards do not require physical scanning.
  - Need to control distribution and disable lost or stolen cards.



3.17 Other Forms of Authentication (2/3)



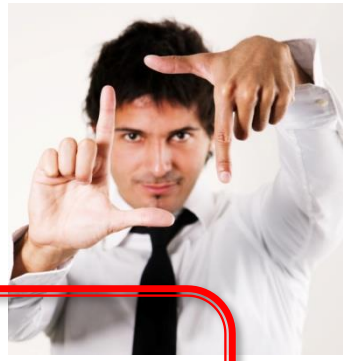
- Biometrics
  - Uses body measurements to authenticate you
  - Methods vary in cost, precision, and ease of deception
  - Fingerprint scanning
    - Inexpensive but poor precision, deceivable
    - Sufficient for low-risk uses
    - On a notebook, may be better than requiring a reusable password



3.17 Other Forms of Authentication (3/3)



- Biometrics
  - Iris scanning
    - Patterns in the colored part of your eye
    - Expensive but precise and difficult to deceive
  - Facial scanning
    - Based on facial features
    - Controversial because it can be done surreptitiously—without the scanned person's knowledge

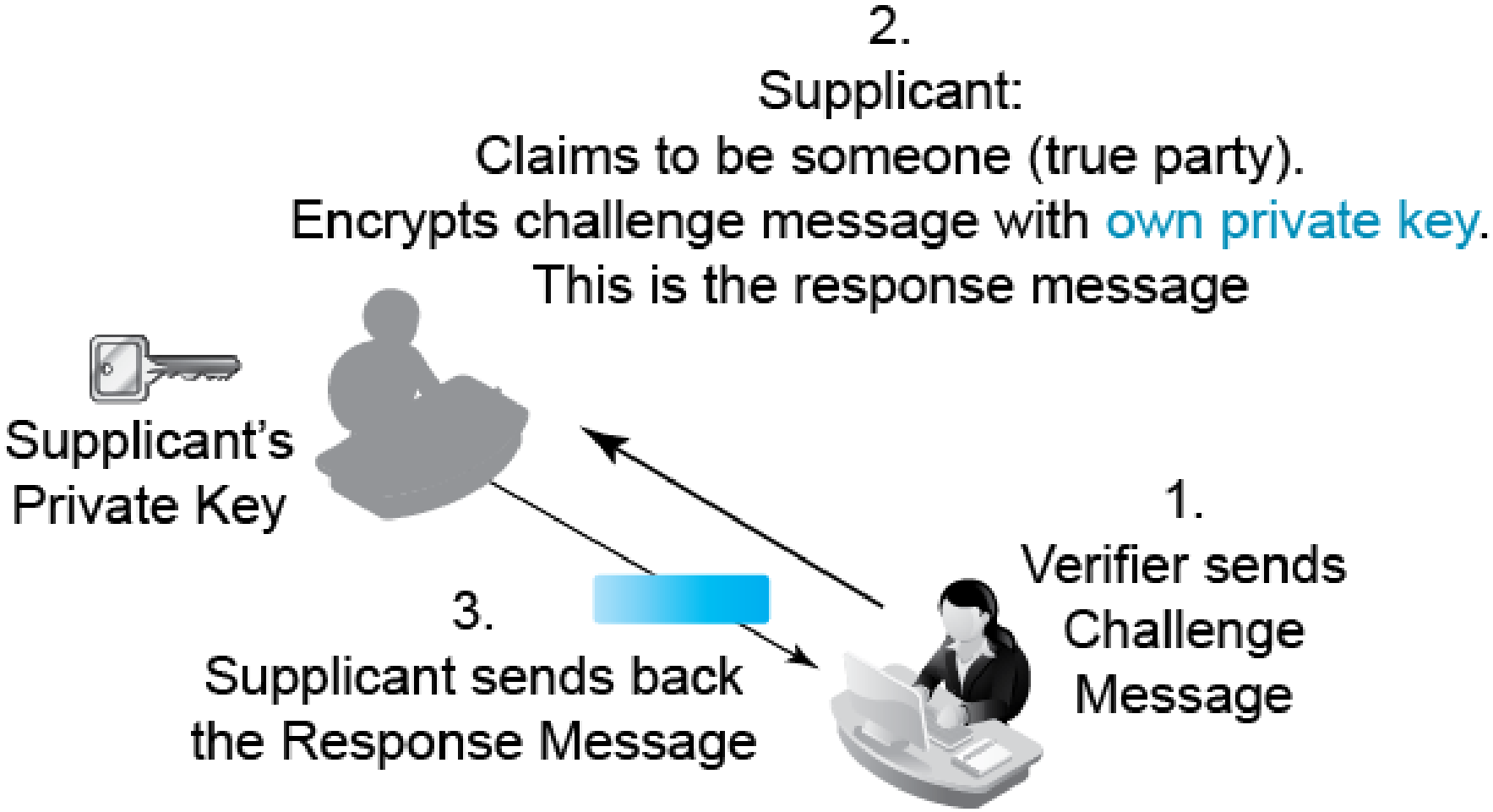


3.18 Digital Certificate Authentication

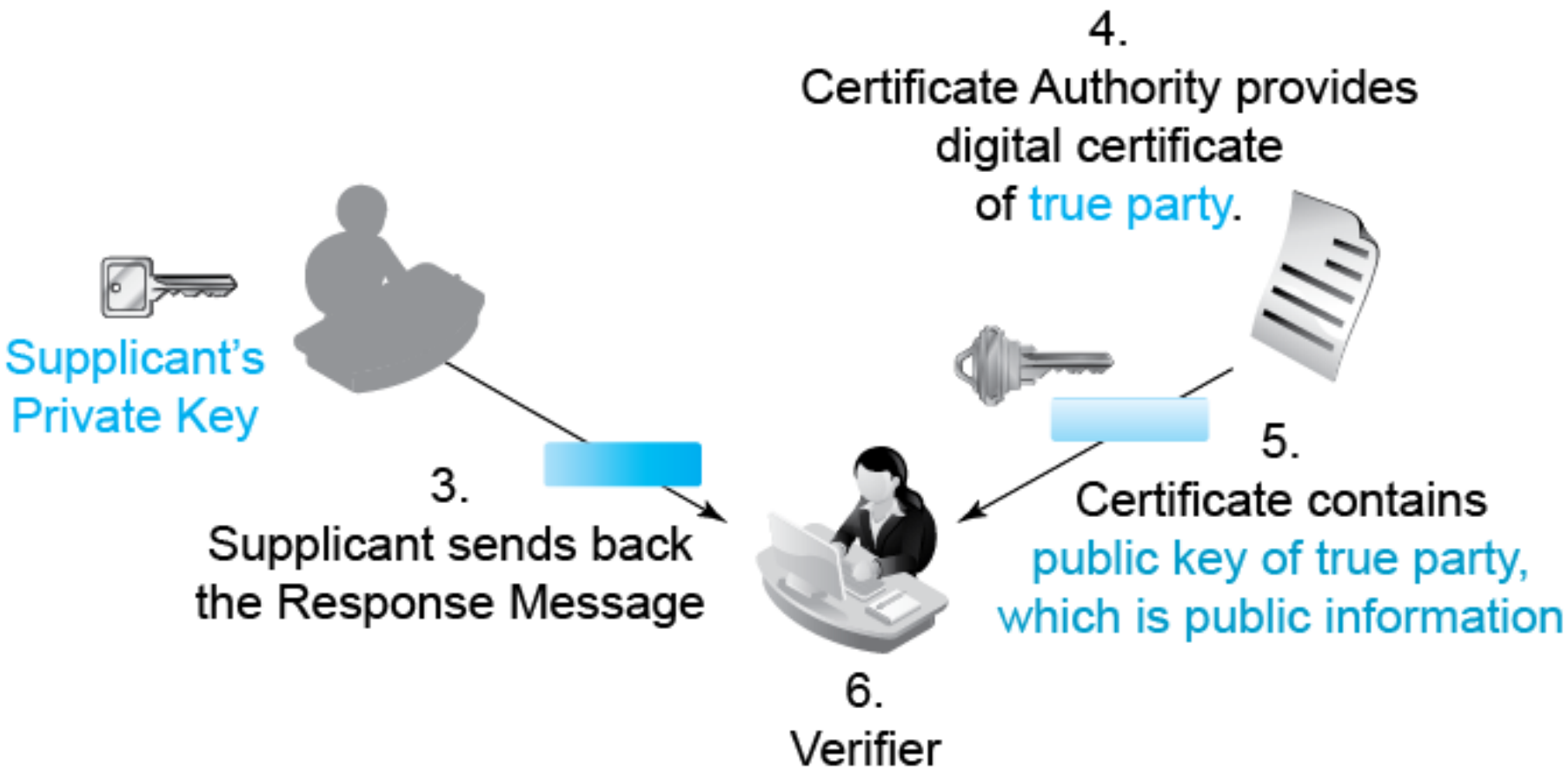


- The strongest form of authentication
- Components
  - Everyone has a private key only he or she knows.
  - Everyone also has a non-secret public key.
  - *Self Test:*
    1. *If John communicates with Sylvia, how many public and private keys will there be?*
    2. *If there are 20 students in the classroom, how many public and private keys will there be?*

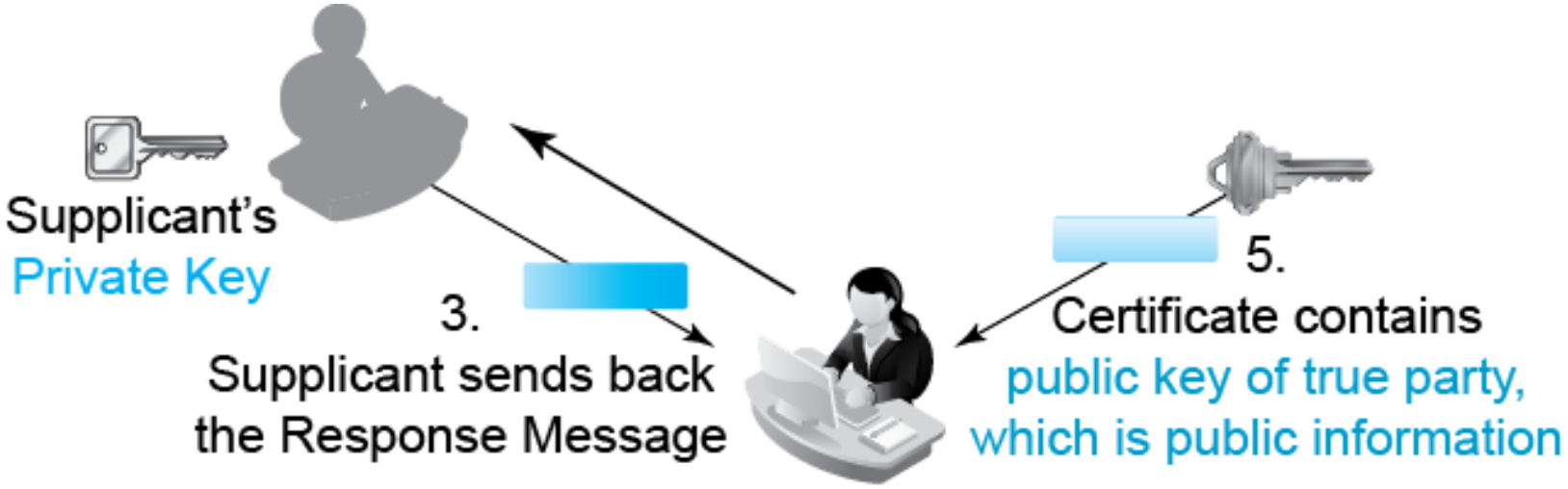
3.18 Digital Certificate Authentication



3.18 Digital Certificate Authentication



3.18 Digital Certificate Authentication



3.18 Digital Certificate Authentication

True Party	Has a Public and Private Key
Supplicant	Encrypts challenge message with supplicant's private key
Verifier	Decrypts response message with true party's public key
Choice	If decryption works, supplicant knows the true party's private key so must be the true party

3.19 Two-Factor Authentication

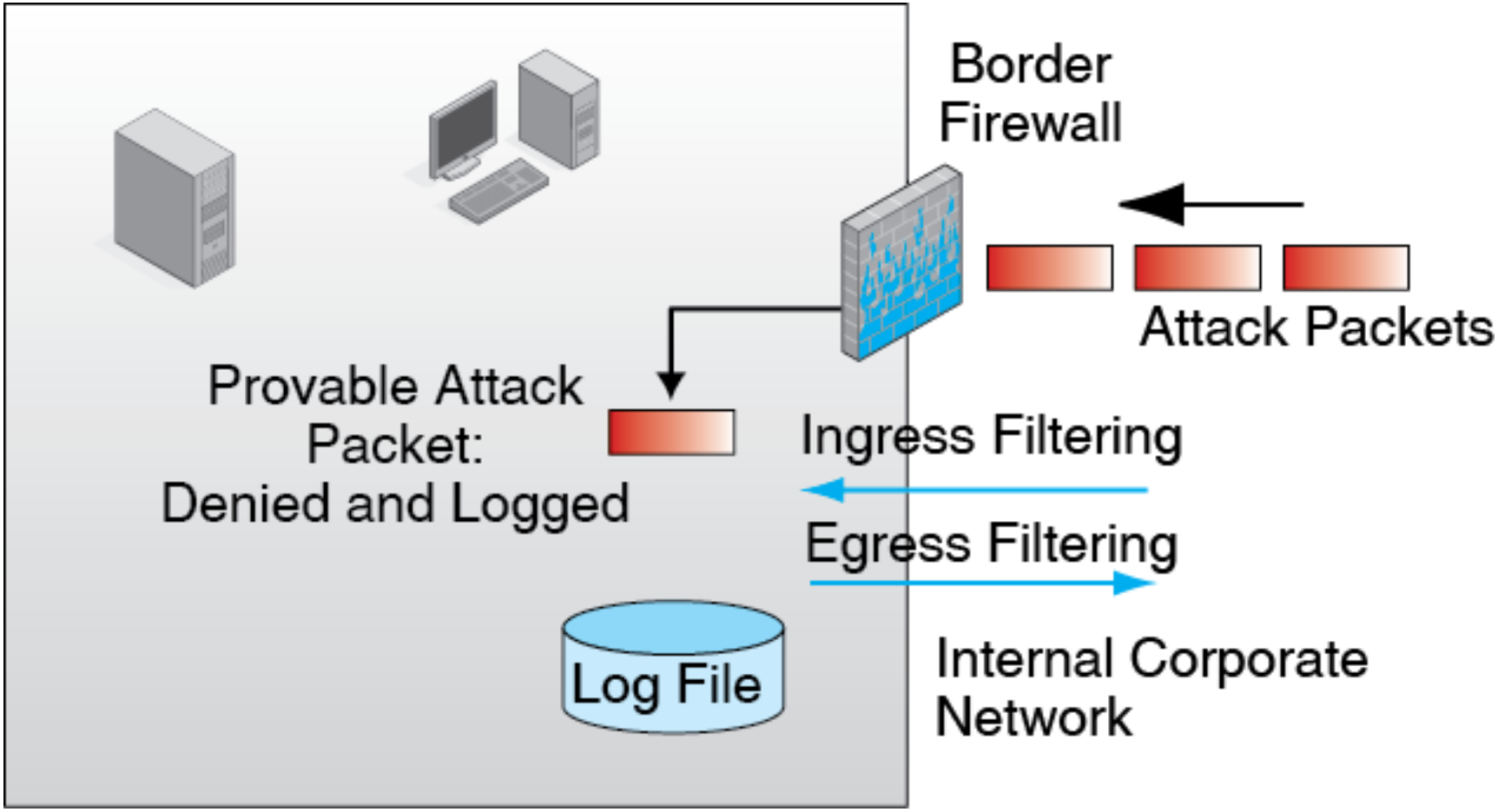
- Two-Factor Authentication
  - Supplicants need two forms of credentials
  - Example: debit card and PIN
  - Strengthens authentication (defense in depth)
  - Fails if attacker controls the user's computer or
  - Intercepts the authentication communication



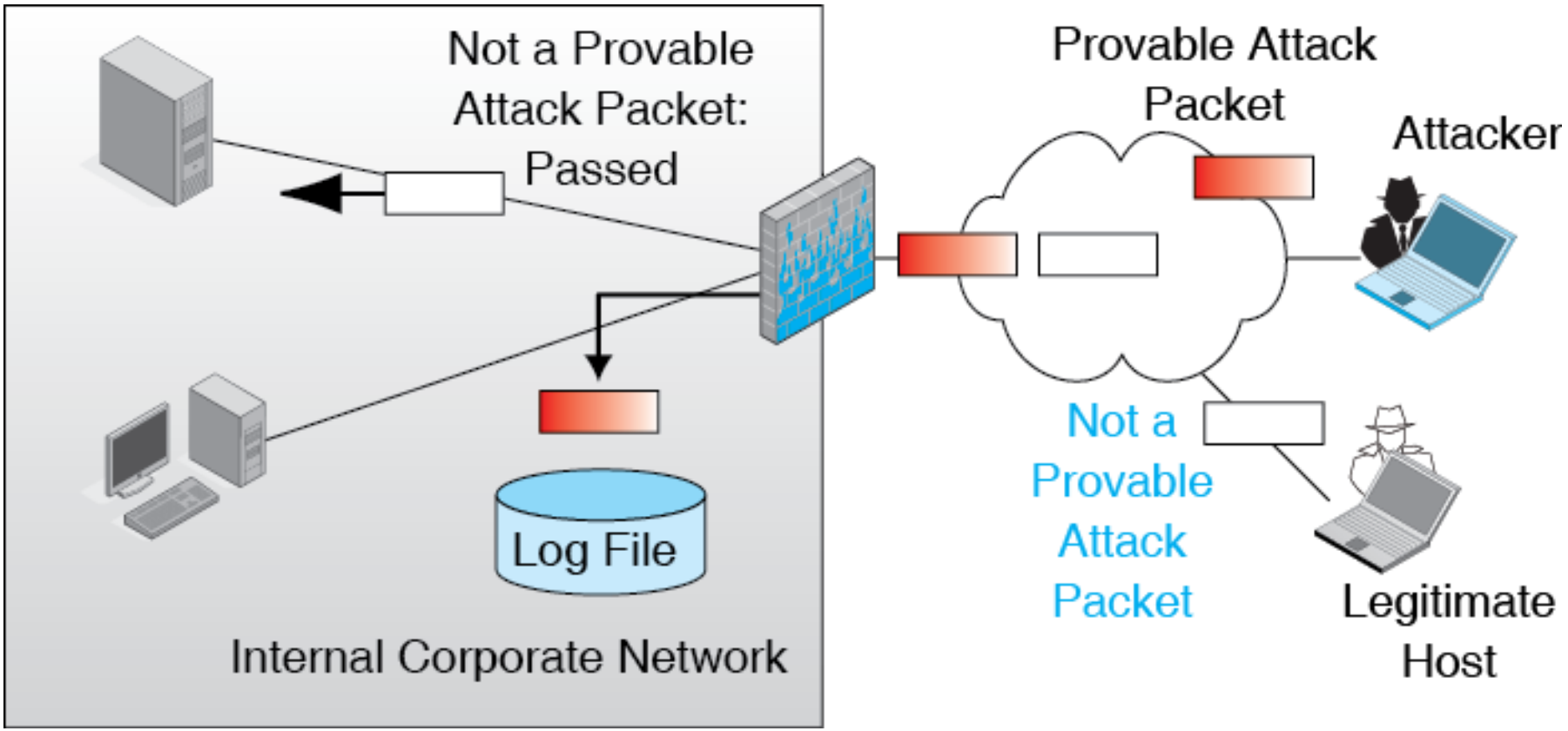
+ 4400 (PIN) = 2-Factor Authentication

- The Target Breach
- Attacks and Attackers
- Protecting Dialogs Cryptographically
- Other Forms of Authentication
- **Firewalls**
- Antivirus Protection

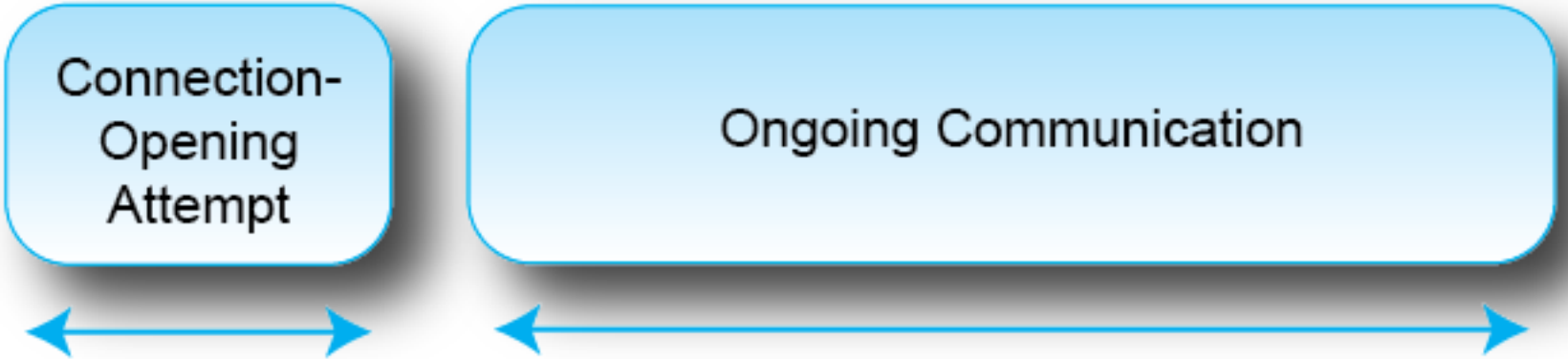
3.20 General Firewall Operation



3.20 General Firewall Operation



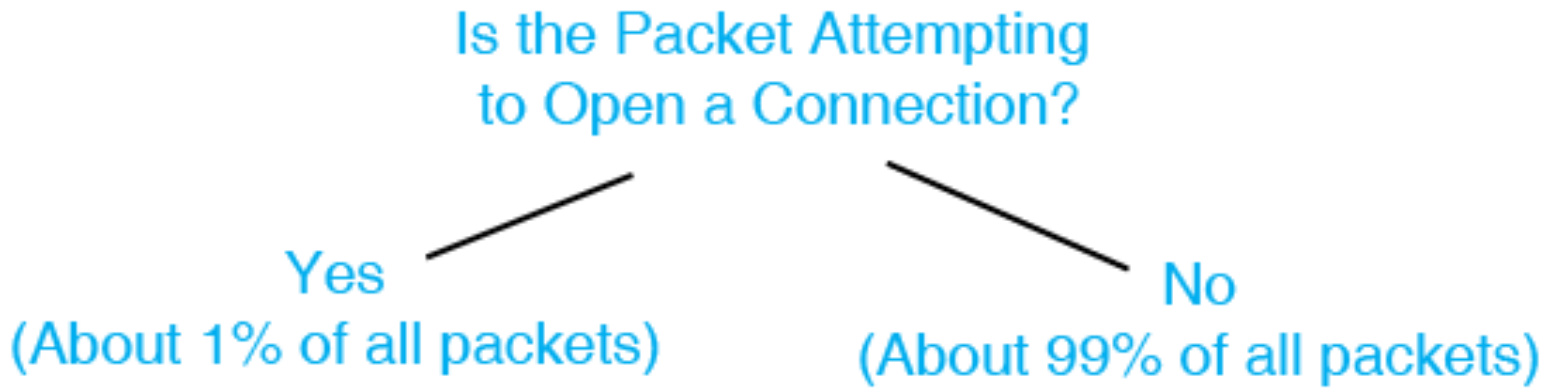
3.21 States in a Conversation



Stateful Inspection Firewalls use the concept of communication states

3.22 Stateful Packet Inspection (SPI)

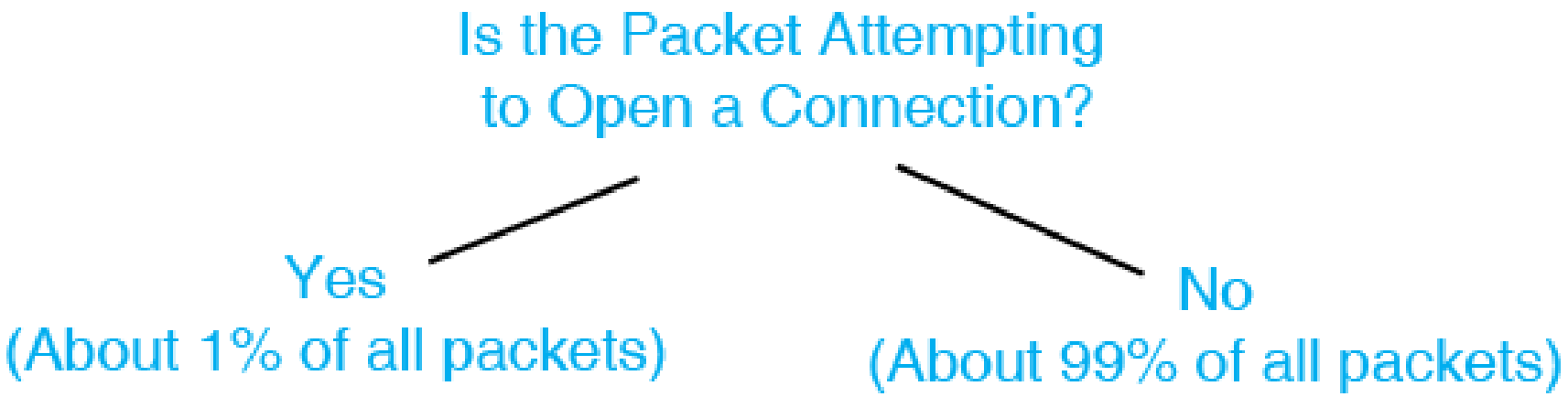
-only do heavy filtering for risky stages of a connection.



What would the firewall do

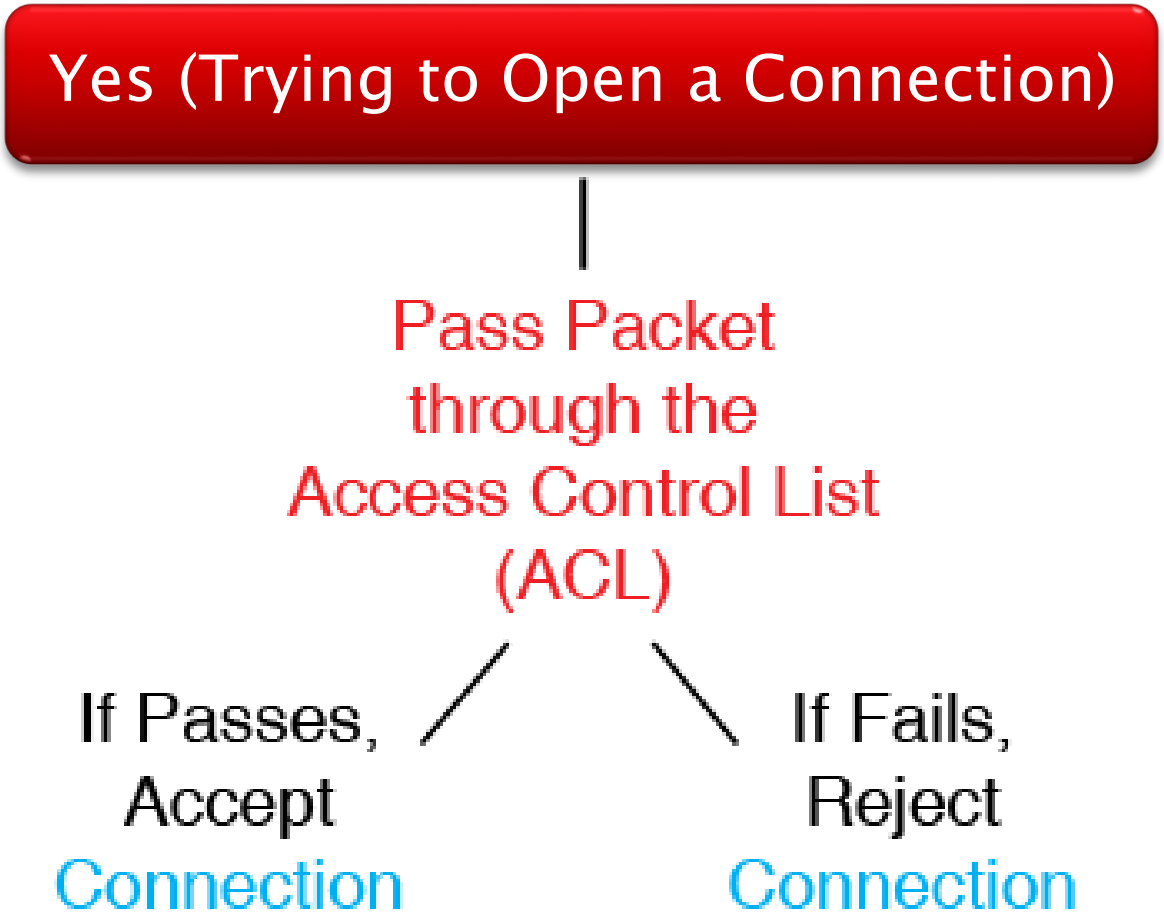
1. *with a packet containing a SYN segment?*
2. *With a packet containing a FIN segment?*
3. *With a packet containing a pure ACK segment?*

3.22 Stateful Packet Inspection (SPI)



What would the firewall do with a packet containing a FIN segment?

3.22 Stateful Packet Inspection (SPI)



3.23 Access Control Lists (ACLs) for Attempts to Open a Connection

Rule	Destination IP Address or Range	Service	Action
1	ALL	25	Allow connection
2	10.47.122.79	80	Allow connection
3	ALL	ALL	Do not allow connection

What will the SPI firewall do if the destination host is 10.47.122.79 and the service is 80?

3.23 Access Control Lists (ACLs) for Attempts to Open a Connection

Rule	Destination IP Address or Range	Service	Action
1	ALL	25	Allow connection
2	10.47.122.79	80	Allow connection
3	ALL	ALL	Disallow connection

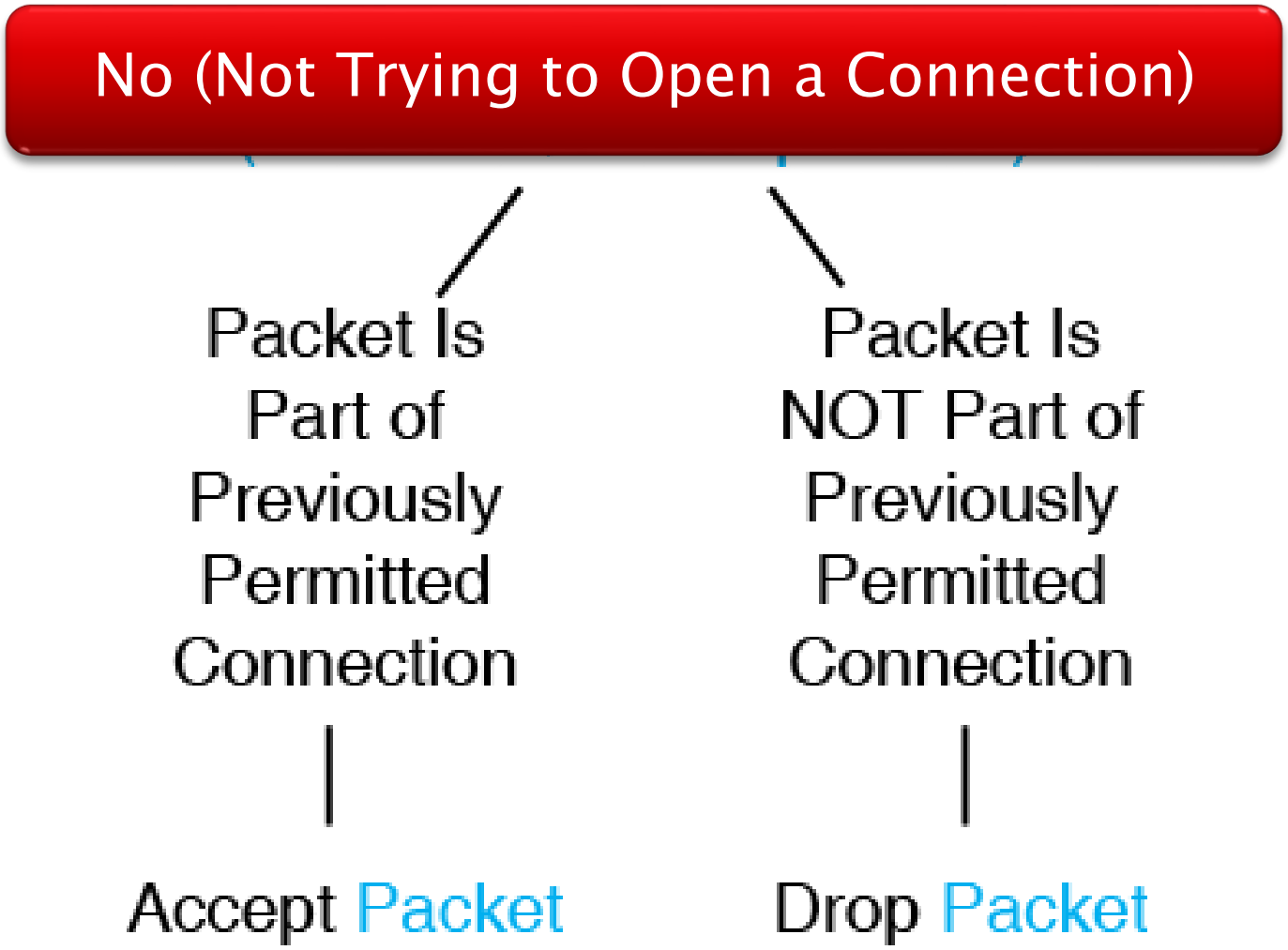
What will the SPI firewall do if the destination host is 10.47.122.79 and the service is 25?

3.23 Access Control Lists (ACLs) for Attempts to Open a Connection

Rule	Destination IP Address or Range	Service	Action
1	ALL	25	Allow connection
2	10.47.122.79	80	Allow connection
5	ALL	ALL	Disallow connection

What packets will match the third row?

3.22 Stateful Packet Inspection (SPI)



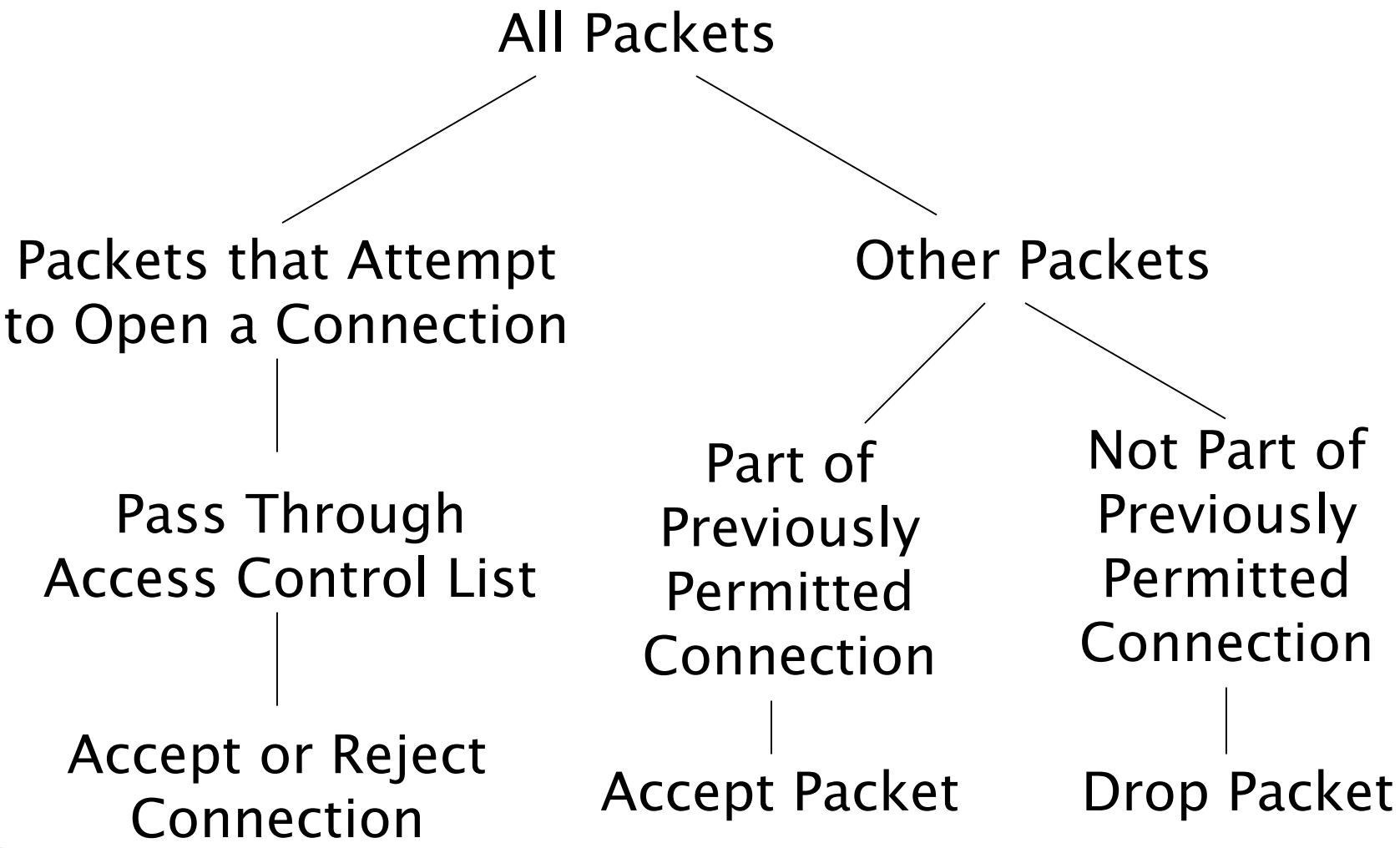
3.22 Stateful Packet Inspection (SPI)

Approved Connections Table

	Internal Host		External Host	
Connec-tion	IP Address	Port	IP Address	Port
1	128.171.17.13	3270	10.74.118.4	80
2	128.171.34.5	4747	60.3.5.75	25

What if the internal IP address is 128.171.34.9, the external IP address is 60.3.5.75 and the source and destination addresses are 4747 and 25?

Summary of Stateful Packet Inspection(SPI)



Limitations of Stateful Packet Inspection (SPI) Firewalls and Solution

1. Limited primarily to examining socket data
2. Cannot detect what applications are actually using Port 80
3. Cannot identify problems in streams of packets

Solution →Next-Generation Firewall (NGFW)

- Uses deep Inspection
  - Examines all fields in the internet and transport layer
  - Examines application layer content as well
- Requires reassembling application messages from multiple segments

3.25 Next-Generation Firewalls (NGFWs) – Features

- **Application Awareness**
  1. Can identify what application created traffic
  2. Can base rules on application policies for specific applications
  3. Even understands malware applications
- **Intrusion Detection System (IDS)** Functionality
  1. Can detect and log suspicious traffic
  2. Notify the security administrator of high-threat suspicious traffic
  3. Produce many false alarms that can dull vigilance

3.25 Next-Generation Firewalls (NGFWs) –Features

- **Intrusion Prevention Systems (IPS)**
  - IDSs that drop packets that are suspicious but for which there is high confidence that they are attacks
- **Reputation Management**
  - Whitelists and blacklists in external reputation management databases
  - Use to inform decisions about packets to and from listed sites
- **NAT and VPN Traversal**
  - Traditional firewall functionality
  - VPN traversal passes encrypted traffic without inspection

3.25 Next-Generation Firewalls (NGFWs) -Features (Cont.)

- **Need Wire-Speed Operation**
  - Processing work per packet is heavy
  - Yet must be able to process at the highest speed of incoming transmission lines
  - Traditional firewalls are general-purpose computers that do processing with step-by-step software
  - NGFWs use purpose-built hardware than can do processing in hardware
    - Much faster than doing the same processing in software

- The Target Breach
- Attacks and Attackers
- Protecting Dialogs Cryptographically
- Other Forms of Authentication
- Firewalls
- **Antivirus Protection**

3.26 Antivirus Protection

- **Firewalls versus Antivirus Filtering**
  - Firewalls work on packets and groups of packets
  - Antivirus filtering works on files
- **Antivirus Filtering**
  - Not limited to viruses
  - Looks for all forms of malware
- **Two Types of Virus Detection**
  - **Signature** Detection vs. **Behavioral** Detection

3.26 Antivirus Protection

- **Signature Detection**
  - Looks for byte patterns that characterize individual malware programs
  - There are now too many malware programs to test for all malware program signatures
  - Also, many malware programs mutate, changing their signatures

3.26 Antivirus Protection

- **Behavioral Detection**
  - Analysis of what the program is attempting to do
  - Reformat the hard drive, etc.
  - If appropriate, delete the program
  - May run programs in a sandbox (environment it cannot escape from) to study it

Summary of Chapter 3

- The Target Breach
- Attacks and Attackers
- Protecting Dialogs Cryptographically
- Other Forms of Authentication
- Firewalls
- Antivirus Protection